API Contract –
PT XYZ Online Lending App

Version 1.1

Document Information

Document ini disusun untuk keperluan memenuhi persyaratan Test.

Base URL

Base URL	https://api.pinjaman.ptxyz.id/v1
Auth	Bearer JWT via POST /auth/token

Daftar Isi

Document Information 2
Base URL 2
Daftar Isi 3
Enumerator Reference 4
HTTP Status Code Reference 4
Auth Service 5
- POST - /auth/token 5
- POST - /auth/token/refresh 7
- POST - /auth/register 9
- POST - /auth/upload-docs 11
- POST - /auth/verify-otp 13
- POST - /auth/biometric-login 15
- POST - /auth/forgot-password 17
- POST - /auth/enable-biometric 18

User Service 20
- GET - /users/profile 20
- GET - /users/bank-accounts 22
- POST - /users/bank-accounts 23
- PUT - /users/bank-accounts/{id} 25

Loan Service 27
- GET - /loans/simulate 27
- POST - /loans/apply 29
- GET - /loans/applications 31
- GET - /loans/applications/{id} 33
- GET - /loans/active 35

Payment Service 37
- POST - /loans/repayments/{repayment_id}/pay 37
- POST - /webhooks/payment-callback 39

Notification Service 41
- GET - /notifications 41
- PUT - /notifications/{id}/read 43

Admin Service 44
- GET - /admin/loans/applications 44
- POST - /admin/loans/applications/{id}/review 46

Enumerator Reference

Enumerators	Valid Value
users.status	PENDING_VERIFICATION, ACTIVE, SUSPENDED, REJECTED
loan_applications.status	PENDING_REVIEW, PENDING_MANUAL_REVIEW, APPROVED, REJECTED, CANCELLED
loans.status	ACTIVE, SETTLED, DEFAULT
loan_repayments.status	UNPAID, PAID, OVERDUE
notifications.type	BILLING_REMINDER, LOAN_APPROVED, LOAN_REJECTED, MARKETING, GENERAL
notifications.channel	EMAIL, SMS, WHATSAPP, IN_APP
credit_score_results.result	PASS, FAIL, MANUAL_REVIEW

HTTP Status Code Reference

Code	Explanations
200 OK	Request berhasil diproses.
201 Created	Resource baru berhasil dibuat.
400 Bad Request	Validasi data gagal atau parameter tidak sesuai.
401 Unauthorized	Token tidak valid atau sudah kadaluarsa.
403 Forbidden	User tidak memiliki izin untuk aksi ini.
404 Not Found	Resource yang diminta tidak ditemukan.
409 Conflict	Kondisi bisnis tidak terpenuhi (misal: pinjaman aktif masih ada).
422 Unprocessable Entity	Format data tidak valid.
429 Too Many Requests	Rate limit terlampaui.
500 Internal Server Error	Terjadi kesalahan pada server.

Auth Service

POST - /auth/token

API Endpoint	/auth/token
API Method	POST
Description	Menghasilkan JWT access_token dan refresh_token berdasarkan kredensial email dan password. Endpoint ini adalah satu-satunya cara untuk mendapatkan token autentikasi yang digunakan pada seluruh endpoint lainnya.
Auth Required	No

API Functionalities

- Memvalidasi kombinasi email dan password.
- Menerapkan rate limit: akun terkunci 15 menit setelah 5 kali gagal login.
- Menghasilkan JWT access_token (TTL: 1 jam) dan refresh_token (TTL: 30 hari).
- Mencatat aktivitas login ke tabel activity_logs.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
email	String	true	Email akun yang terdaftar
password	String	true	Password akun.

Request Example

```
{
  "email"    : "budi@email.com",
  "password" : "Str0ngP@ss!"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika token berhasil dihasilkan.
access_token	String	JWT access token. Sertakan di header Authorization: Bearer {token}. TTL: 1 jam.

Field	Data Type	Description
refresh_token	String	JWT refresh token untuk memperbarui access_token. TTL: 30 hari.
token_type	String	Selalu "Bearer".
expires_in	Integer	Masa berlaku access_token dalam detik (3600).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...", "refresh_token": "eyJhbGci...", "token_type": "Bearer", "expires_in": 3600 }`
401 Unauthorized	`{ "success": false, "error": "Email atau password salah." }`
429 Too Many Req.	`{ "success": false, "error": "Akun terkunci selama 15 menit akibat terlalu banyak percobaan gagal." }`

POST - /auth/token/refresh

API Endpoint	/auth/token/refresh
API Method	POST
Description	Memperbarui JWT access_token menggunakan refresh_token yang masih valid, tanpa perlu login ulang.
Auth Required	No

API Functionalities

- Memvalidasi refresh_token dan memastikan belum kadaluarsa.
- Menghasilkan access_token baru dengan TTL 1 jam.
- Refresh token lama tetap valid hingga masa berlakunya habis.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
refresh_token	String	true	JWT refresh token yang diperoleh dari POST /auth/token

Request Example

```
{
  "refresh_token" : "eyJhbGci..."
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika access_token berhasil diperbarui.
access_token	String	JWT access token baru. TTL: 1 jam.
expires_in	Integer	Masa berlaku dalam detik (3600).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "access_token": "eyJhbGci...", "expires_in": 3600 }`

Status	Body (contoh)
401 Unauthorized	`{ "success": false, "error": "Refresh token tidak valid atau sudah kadaluarsa." }`

POST - /auth/register

API Endpoint	/auth/register
API Method	POST
Description	Mendaftarkan user baru dengan data diri. Setelah berhasil, user menerima OTP via SMS untuk verifikasi nomor HP.
Auth Required	No

API Functionalities

- Memvalidasi format NIK (16 digit), email, nomor HP, dan password.
- Memeriksa duplikat NIK, email, dan nomor HP di database.
- Menyimpan data user dengan status PENDING_VERIFICATION.
- Mengembalikan user_id untuk proses upload dokumen berikutnya.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
full_name	String	true	Nama lengkap sesuai KTP
nik	String	true	Nomor Induk Kependudukan 16 digit.
birth_place	String	true	Tempat lahir.
birth_date	String	true	Tanggal lahir format YYYY-MM-DD.
email	String	true	Alamat email aktif. Harus unik.
phone	String	true	Nomor HP format 08xx atau +62xx. Harus unik.
password	String	true	Min 8 karakter, kombinasi huruf dan angka.

Request Example

```
{
  "full_name"   : "Budi Santoso",
  "nik"         : "3201011234560001",
  "birth_place" : "Bandung",
  "birth_date"  : "1990-01-12",
  "email"       : "budi@email.com",
  "phone"       : "081234567890",
  "password"    : "Str0ngP@ss!"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika registrasi berhasil.
user_id	String (UUID)	ID unik user yang baru terdaftar.
message	String	Pesan konfirmasi bahwa OTP telah dikirim.

Response Example

Status	Body (contoh)
201 Created	`{ "success": true, "user_id": "uuid-xxx", "message": "OTP dikirim ke nomor HP" }`
400 Bad Request	`{ "success": false, "error": "NIK sudah terdaftar." }`
422 Unprocessable	`{ "success": false, "error": "Format email tidak valid." }`

POST - /auth/upload-docs

API Endpoint	/auth/upload-docs
API Method	POST
Description	Mengunggah foto pribadi, foto KTP, dan selfie bersama KTP sebagai bagian dari proses registrasi. Menggunakan multipart/form-data.
Auth Required	No

API Functionalities

- Menerima 3 file: foto_pribadi, foto_ktp, dan selfie_ktp.
- Memvalidasi format file (JPG/PNG) dan ukuran maksimum 5 MB per file.
- Mengunggah ke object storage (S3/MinIO) dan menghasilkan URL publik.
- Menyimpan URL dokumen ke record user.

Request Header

Field	Description
Authorization	Bearer {access_token}. Obtain from POST /auth/token.
Content-Type	multipart/form-data

Request Body

Field	Data Type	Mandatory	Description
user_id	String (UUID)	true	ID user dari response registrasi
photo	File	true	Foto wajah. Format JPG/PNG, maks 5 MB.
ktp_photo	File	true	Foto KTP tampak depan. Format JPG/PNG, maks 5 MB.
selfie_ktp	File	true	Selfie sambil memegang KTP. Format JPG/PNG, maks 5 MB.

Request Example

```
// multipart/form-data
user_id    : "uuid-xxx"
photo      : [file binary]
ktp_photo  : [file binary]
selfie_ktp : [file binary]
```

Response Body

Field	Data Type	Description
success	Boolean	true jika semua file berhasil diunggah.
photo_url	String	URL foto pribadi yang tersimpan.

Field	Data Type	Description
ktp_photo_url	String	URL foto KTP yang tersimpan.
selfie_ktp_url	String	URL foto selfie+KTP yang tersimpan.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "photo_url": "https://cdn.../photo.jpg", "ktp_photo_url": "https://cdn.../ktp.jpg", "selfie_ktp_url": "https://cdn.../selfie.jpg" }`
400 Bad Request	`{ "success": false, "error": "File foto melebihi batas 5 MB." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

POST - /auth/verify-otp

API Endpoint	/auth/verify-otp
API Method	POST
Description	Memverifikasi kode OTP 6 digit yang dikirim ke nomor HP user untuk mengaktifkan akun.
Auth Required	No

API Functionalities

- Memvalidasi kode OTP dan masa berlakunya (TTL 5 menit).
- Mengubah status user dari PENDING_VERIFICATION menjadi ACTIVE.
- Mengembalikan JWT access_token dan refresh_token jika OTP valid.
- OTP hangus setelah berhasil digunakan.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
user_id	String (UUID)	true	ID user dari response registrasi
otp_code	String	true	Kode OTP 6 digit.

Request Example

```
{
  "user_id"  : "uuid-xxx",
  "otp_code" : "182736"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika OTP valid dan akun berhasil diaktifkan.
access_token	String	JWT access token.
refresh_token	String	JWT refresh token.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "access_token": "eyJ...", "refresh_token": "eyJ..." }`
400 Bad Request	`{ "success": false, "error": "Kode OTP salah atau sudah kadaluarsa." }`

POST - /auth/biometric-login

API Endpoint	/auth/biometric-login
API Method	POST
Description	Login menggunakan biometric token dari perangkat user (fingerprint / Face ID) tanpa perlu memasukkan password.
Auth Required	No

API Functionalities

- Memvalidasi device_id yang telah terdaftar pada akun user.
- Memverifikasi bio_token yang telah ditandatangani oleh perangkat.
- Mengembalikan JWT access_token dan refresh_token.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
device_id	String	true	ID unik perangkat yang telah didaftarkan
bio_token	String	true	Token biometric bertanda tangan dari perangkat.

Request Example

```
{
  "device_id" : "device-uuid-xyz",
  "bio_token" : "signed-token-abc"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika biometric berhasil diverifikasi.
access_token	String	JWT access token.
refresh_token	String	JWT refresh token.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "access_token": "eyJ...", "refresh_token": "eyJ..." }`
401 Unauthorized	`{ "success": false, "error": "Biometric token tidak valid atau device tidak dikenal." }`

POST - /auth/forgot-password

API Endpoint	/auth/forgot-password
API Method	POST
Description	Mengirimkan link reset password ke email terdaftar. Respons selalu 200 OK untuk mencegah user enumeration.
Auth Required	No

API Functionalities

- Memeriksa apakah email terdaftar di sistem.
- Membuat reset token unik dengan TTL 1 jam dan menyimpannya di Redis.
- Mengirimkan email berisi link reset password.
- Respons selalu 200 OK untuk mencegah eksploitasi user enumeration.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
email	String	true	Email akun yang akan direset

Request Example

```
{
  "email" : "budi@email.com"
}
```

Response Body

Field	Data Type	Description
success	Boolean	Selalu true untuk mencegah user enumeration.
message	String	Pesan instruksi untuk user.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Jika email terdaftar, link reset telah dikirimkan." }`

POST - /auth/enable-biometric

API Endpoint	/auth/enable-biometric
API Method	POST
Description	Mendaftarkan atau menonaktifkan fitur biometric login pada perangkat user yang sedang aktif.
Auth Required	Yes

API Functionalities

- Memvalidasi JWT access_token milik user yang login.
- Menyimpan pasangan device_id dan bio_token ke database.
- Jika enable=false, menghapus entri biometric untuk device_id terkait.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
device_id	String	true	ID unik perangkat
bio_token	String	true	Token biometric dari perangkat. Wajib jika enable=true.
enable	Boolean	true	true untuk mengaktifkan, false untuk menonaktifkan.

Request Example

```
{
  "device_id" : "device-uuid-xyz",
  "bio_token" : "signed-token-abc",
  "enable"    : true
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika operasi berhasil.
message	String	Pesan konfirmasi.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Biometric login berhasil diaktifkan." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

User Service

GET - /users/profile

API Endpoint	/users/profile
API Method	GET
Description	Mengambil data profil user yang sedang login beserta ringkasan keuangan pinjaman aktif.
Auth Required	Yes

API Functionalities

- Mengembalikan data identitas user dari database.
- Menghitung sisa hutang, tagihan bulanan, dan tanggal jatuh tempo dari pinjaman aktif.
- Menampilkan available_limit jika user tidak memiliki pinjaman aktif.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Example

```
// Tidak ada request body. GET request.
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
user_id	String (UUID)	ID unik user.
full_name	String	Nama lengkap user.
email	String	Email user.
phone	String	Nomor HP user.
has_active_loan	Boolean	true jika user memiliki pinjaman aktif.
outstanding_balance	Integer	Total sisa hutang dalam Rupiah.
monthly_bill	Integer	Nominal cicilan per bulan.
next_due_date	String	Tanggal jatuh tempo berikutnya (YYYY-MM-DD).
next_due_amount	Integer	Nominal tagihan yang akan jatuh tempo.
available_limit	Integer	Limit pinjaman tersedia. 0 jika ada pinjaman aktif.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "user_id": "uuid-xxx", "full_name": "Budi Santoso", "has_active_loan": true, "outstanding_balance": 4000000, "monthly_bill": 1100000, "next_due_date": "2024-02-15", "next_due_amount": 1100000, "available_limit": 0 }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

GET - /users/bank-accounts

API Endpoint	/users/bank-accounts
API Method	GET
Description	Mengambil daftar rekening bank pencairan pinjaman yang terdaftar pada akun user.
Auth Required	Yes

API Functionalities

- Mengembalikan semua rekening bank yang tersimpan milik user.
- Menandai rekening yang sedang aktif digunakan sebagai rekening pencairan.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Example

```
// Tidak ada request body. GET request.
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
bank_accounts	Array	Daftar rekening bank user.
bank_accounts[].id	String (UUID)	ID rekening.
bank_accounts[].bank_name	String	Nama bank (contoh: BCA, Mandiri).
bank_accounts[].account_number	String	Nomor rekening.
bank_accounts[].account_name	String	Nama pemilik rekening.
bank_accounts[].is_active	Boolean	true jika ini rekening pencairan yang aktif.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "bank_accounts": [{ "id": "uuid-yyy", "bank_name": "BCA", "account_number": "1234567890", "account_name": "Budi Santoso", "is_active": true }] }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

POST - /users/bank-accounts

API Endpoint	/users/bank-accounts
API Method	POST
Description	Menambahkan rekening bank baru sebagai rekening pencairan pinjaman. Rekening akan diverifikasi terlebih dahulu melalui API Bank sebelum disimpan.
Auth Required	Yes

API Functionalities

- Memvalidasi nomor rekening melalui Bank API.
- Menyimpan rekening yang telah terverifikasi ke database.
- Maksimal 3 rekening tersimpan per user.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
bank_name	String	true	Nama bank (contoh: BCA, Mandiri, BNI)
account_number	String	true	Nomor rekening bank.
account_name	String	true	Nama pemilik rekening sesuai data bank.

Request Example

```
{
  "bank_name"      : "BCA",
  "account_number" : "1234567890",
  "account_name"   : "Budi Santoso"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika rekening berhasil disimpan.
id	String (UUID)	ID rekening bank yang baru ditambahkan.
message	String	Pesan konfirmasi.

Response Example

Status	Body (contoh)
201 Created	`{ "success": true, "id": "uuid-yyy", "message": "Rekening berhasil ditambahkan." }`
400 Bad Request	`{ "success": false, "error": "Rekening tidak valid menurut data bank." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

PUT - /users/bank-accounts/{id}

API Endpoint	/users/bank-accounts/{id}
API Method	PUT
Description	Mengubah data rekening bank pencairan pinjaman. Hanya data rekening yang dapat diubah; data identitas user (nama, NIK, email) tidak dapat diubah.
Auth Required	Yes

API Functionalities

- Memvalidasi kepemilikan rekening oleh user yang sedang login.
- Memverifikasi rekening baru melalui Bank API sebelum disimpan.
- Menggantikan data rekening lama dengan data rekening baru.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
bank_name	String	true	Nama bank baru
account_number	String	true	Nomor rekening baru.
account_name	String	true	Nama pemilik rekening baru.

Request Example

```
{
  "bank_name"      : "Mandiri",
  "account_number" : "9876543210",
  "account_name"   : "Budi Santoso"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika rekening berhasil diperbarui.
message	String	Pesan konfirmasi.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Rekening berhasil diperbarui." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
403 Forbidden	`{ "success": false, "error": "Rekening ini bukan milik Anda." }`

Loan Service

GET - /loans/simulate

API Endpoint	/loans/simulate
API Method	GET
Description	Menghitung simulasi cicilan pinjaman berdasarkan nominal dan tenor. Tidak memerlukan autentikasi sehingga dapat diakses oleh calon peminjam.
Auth Required	No

API Functionalities

- Menghitung cicilan bulanan menggunakan metode bunga flat.
- Menghasilkan jadwal cicilan lengkap beserta breakdown pokok dan bunga per bulan.
- Memvalidasi batas nominal (maks Rp 12.000.000) dan tenor (maks 12 bulan).

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
amount	Integer	true	Nominal pinjaman dalam Rupiah. Min: 1.000.000. Maks: 12.000.000. Query param
tenor	Integer	true	Tenor dalam bulan. Min: 1. Maks: 12. Query param.

Request Example

```
// Query Parameters:
GET /loans/simulate?amount=6000000&tenor=6
```

Response Body

Field	Data Type	Description
success	Boolean	true jika kalkulasi berhasil.
amount	Integer	Nominal pinjaman.
tenor_months	Integer	Tenor dalam bulan.
interest_rate	Number	Bunga per bulan dalam persen (flat).

Field	Data Type	Description
monthly_payment	Integer	Total cicilan per bulan.
total_payment	Integer	Total pembayaran selama tenor.
schedule	Array	Jadwal cicilan lengkap per bulan.
schedule[].month	Integer	Urutan bulan cicilan.
schedule[].due_date	String	Tanggal jatuh tempo (YYYY-MM-DD).
schedule[].amount	Integer	Total cicilan bulan tersebut.
schedule[].principal	Integer	Komponen pokok cicilan.
schedule[].interest	Integer	Komponen bunga cicilan.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "amount": 6000000, "tenor_months": 6, "interest_rate": 2.5, "monthly_payment": 1100000, "total_payment": 6600000, "schedule": [{ "month": 1, "due_date": "2024-02-15", "amount": 1100000, "principal": 1000000, "interest": 100000 }] }`
400 Bad Request	`{ "success": false, "error": "Nominal melebihi batas maksimum Rp 12.000.000." }`

POST - /loans/apply

API Endpoint	/loans/apply
API Method	POST
Description	Mengajukan pinjaman baru. User tidak dapat memiliki lebih dari satu pinjaman aktif secara bersamaan.
Auth Required	Yes

API Functionalities

- Memeriksa apakah user memiliki pinjaman aktif. Jika ada, request ditolak dengan 409 Conflict.
- Memvalidasi nominal (maks Rp 12.000.000) dan tenor (maks 12 bulan).
- Membuat record loan_application dengan status PENDING_REVIEW.
- Mengirimkan notifikasi konfirmasi pengajuan via email dan SMS.
- Memicu proses risk scoring otomatis di background.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
amount	Integer	true	Nominal pinjaman dalam Rupiah. Maks: 12.000.000
tenor_months	Integer	true	Tenor dalam bulan. Maks: 12.
bank_account_id	String (UUID)	true	ID rekening bank pencairan.

Request Example

```
{
  "amount"          : 6000000,
  "tenor_months"    : 6,
  "bank_account_id" : "uuid-yyy"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika pengajuan berhasil dibuat.
application_id	String (UUID)	ID pengajuan pinjaman.
status	String	Status awal: PENDING_REVIEW.

Field	Data Type	Description
message	String	Pesan konfirmasi.

Response Example

Status	Body (contoh)
201 Created	`{ "success": true, "application_id": "uuid-zzz", "status": "PENDING_REVIEW", "message": "Pengajuan sedang diproses." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
409 Conflict	`{ "success": false, "error": "Tidak dapat mengajukan pinjaman baru. Pinjaman sebelumnya belum lunas." }`
400 Bad Request	`{ "success": false, "error": "Tenor melebihi batas maksimum 12 bulan." }`

GET - /loans/applications

API Endpoint	/loans/applications
API Method	GET
Description	Mengambil riwayat semua pengajuan pinjaman milik user yang sedang login.
Auth Required	Yes

API Functionalities

- Mengembalikan daftar semua pengajuan pinjaman user dengan urutan terbaru lebih dahulu.
- Mendukung filter berdasarkan status dan pagination.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Body

Field	Data Type	Mandatory	Description
status	String	false	Filter status pengajuan Query param
page	Integer	true	Halaman. Default: 1. Query param.
limit	Integer	true	Item per halaman. Default: 20. Query param.

Request Example

```
// Query Parameters:
GET /loans/applications?status=APPROVED&page=1&limit=20
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
total	Integer	Total jumlah pengajuan.
applications	Array	Daftar pengajuan pinjaman.
applications[].id	String (UUID)	ID pengajuan.
applications[].amount	Integer	Nominal pinjaman.
applications[].tenor_months	Integer	Tenor dalam bulan.
applications[].status	String	Status pengajuan saat ini.
applications[].created_at	String	Waktu pengajuan (ISO 8601).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "total": 2, "applications": [{ "id": "uuid-zzz", "amount": 6000000, "tenor_months": 6, "status": "APPROVED", "created_at": "2024-01-15T10:00:00Z" }] }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

GET - /loans/applications/{id}

API Endpoint	/loans/applications/{id}
API Method	GET
Description	Mengambil detail satu pengajuan pinjaman tertentu milik user.
Auth Required	Yes

API Functionalities

- Memvalidasi kepemilikan pengajuan oleh user yang sedang login.
- Mengembalikan detail lengkap pengajuan termasuk risk score dan alasan penolakan.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Example

```
// Tidak ada request body. GET request.
GET /loans/applications/uuid-zzz
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
id	String (UUID)	ID pengajuan.
amount	Integer	Nominal pinjaman.
tenor_months	Integer	Tenor dalam bulan.
monthly_payment	Integer	Cicilan per bulan.
status	String	Status pengajuan.
risk_score	Number	Skor risiko dari risk engine (0-100).
rejection_reason	String	Alasan penolakan jika status REJECTED. Null jika tidak ada.
reviewed_at	String	Waktu review oleh Admin (ISO 8601). Null jika belum.
created_at	String	Waktu pengajuan (ISO 8601).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "id": "uuid-zzz", "amount": 6000000, "tenor_months": 6, "monthly_payment": 1100000, "status": "APPROVED", "risk_score": 72.5,`

Status	Body (contoh)
	"rejection_reason": null, "reviewed_at": "2024-01-16T08:00:00Z", "created_at": "2024-01-15T10:00:00Z" }
401 Unauthorized	{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }
404 Not Found	{ "success": false, "error": "Pengajuan tidak ditemukan." }

GET - /loans/active

API Endpoint	/loans/active
API Method	GET
Description	Mengambil detail pinjaman aktif milik user beserta jadwal cicilan lengkap.
Auth Required	Yes

API Functionalities

- Mengembalikan detail pinjaman aktif beserta saldo outstanding.
- Menyertakan jadwal cicilan lengkap dengan status pembayaran tiap bulan.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Example

```
// Tidak ada request body. GET request.
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
loan_id	String (UUID)	ID pinjaman aktif.
amount	Integer	Nominal pokok pinjaman.
outstanding_balance	Integer	Sisa hutang yang belum dibayar.
tenor_months	Integer	Tenor pinjaman dalam bulan.
status	String	Status pinjaman: ACTIVE, SETTLED, atau DEFAULT.
disbursed_at	String	Waktu pencairan dana (ISO 8601).
repayment_schedule	Array	Jadwal cicilan.
repayment_schedule[].id	String (UUID)	ID cicilan.
repayment_schedule[].due_date	String	Tanggal jatuh tempo (YYYY-MM-DD).
repayment_schedule[].amount	Integer	Nominal cicilan.
repayment_schedule[].principal	Integer	Komponen pokok.
repayment_schedule[].interest	Integer	Komponen bunga.
repayment_schedule[].status	String	UNPAID, PAID, atau OVERDUE.

Field	Data Type	Description
repayment_schedule[].paid_at	String	Waktu lunas. Null jika belum dibayar.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "loan_id": "uuid-aaa", "amount": 6000000, "outstanding_balance": 4000000, "tenor_months": 6, "status": "ACTIVE", "disbursed_at": "2024-01-17T00:00:00Z", "repayment_schedule": [{ "id": "uuid-r1", "due_date": "2024-02-15", "amount": 1100000, "principal": 1000000, "interest": 100000, "status": "PAID", "paid_at": "2024-02-14" }] }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
404 Not Found	`{ "success": false, "error": "Tidak ada pinjaman aktif untuk user ini." }`

Payment Service

POST - /loans/repayments/{repayment_id}/pay

API Endpoint	/loans/repayments/{repayment_id}/pay
API Method	POST
Description	Menghasilkan nomor Virtual Account (VA) sebagai kode pembayaran untuk cicilan tertentu. VA berlaku hingga pukul 23:59 pada tanggal jatuh tempo.
Auth Required	Yes

API Functionalities

- Memvalidasi kepemilikan repayment oleh user yang sedang login.
- Memastikan status cicilan adalah UNPAID atau OVERDUE.
- Meminta nomor VA ke Payment Gateway (Xendit/Midtrans).
- Menyimpan nomor VA dan external_id ke record repayment.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
bank_code	String	true	Kode bank untuk VA. Nilai valid: BCA, BNI, BRI, MANDIRI

Request Example

```
{
  "bank_code" : "BCA"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika VA berhasil dibuat.
va_number	String	Nomor Virtual Account untuk pembayaran.
bank_code	String	Kode bank VA.
amount	Integer	Nominal yang harus dibayar.
expiry_date	String	Batas waktu pembayaran (ISO 8601).

Field	Data Type	Description
external_id	String	ID referensi untuk rekonsiliasi dengan Payment Gateway.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "va_number": "8277001234567890", "bank_code": "BCA", "amount": 1100000, "expiry_date": "2024-02-15T23:59:00+07:00", "external_id": "TRX202402140001" }`
400 Bad Request	`{ "success": false, "error": "Tagihan ini sudah berstatus PAID." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
403 Forbidden	`{ "success": false, "error": "Cicilan ini bukan milik Anda." }`

POST - /webhooks/payment-callback

API Endpoint	/webhooks/payment-callback
API Method	POST
Description	Endpoint webhook yang dipanggil oleh Payment Gateway setelah user melakukan pembayaran. Divalidasi menggunakan callback token dari Payment Gateway, bukan JWT user.
Auth Required	No

API Functionalities

- Memvalidasi X-Callback-Token dari Payment Gateway untuk keamanan.
- Mencocokkan external_id dengan record repayment.
- Memvalidasi kesesuaian nominal pembayaran.
- Mengubah status repayment menjadi PAID dan mencatat waktu pembayaran.
- Menghitung ulang outstanding_balance pada tabel loans.
- Mengubah status loan menjadi SETTLED jika semua cicilan lunas.
- Mengirimkan notifikasi konfirmasi pembayaran ke user via email dan SMS.

Request Header

Field	Description
Authorization	Bearer <<Authorization Token>>
Content-Type	application/json
X-Callback-Token	Signature token dari Payment Gateway.

Request Body

Field	Data Type	Mandatory	Description
external_id	String	true	ID referensi yang diberikan saat membuat VA
status	String	true	Status pembayaran dari Payment Gateway: PAID.
amount	Integer	true	Nominal yang dibayarkan user.
paid_at	String	true	Waktu pembayaran dalam format ISO 8601.
bank_code	String	true	Kode bank yang digunakan untuk pembayaran.

Request Example

```
{
  "external_id" : "TRX202402140001",
  "status"      : "PAID",
  "amount"      : 1100000,
  "paid_at"     : "2024-02-14T14:32:00+07:00",
  "bank_code"   : "BCA"
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika webhook berhasil diproses.
message	String	Konfirmasi penerimaan webhook.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Webhook acknowledged." }`
401 Unauthorized	`{ "success": false, "error": "Callback token tidak valid." }`
404 Not Found	`{ "success": false, "error": "external_id tidak ditemukan." }`

Notification Service

GET - /notifications

API Endpoint	/notifications
API Method	GET
Description	Mengambil daftar notifikasi milik user yang sedang login dengan dukungan pagination dan filter.
Auth Required	Yes

API Functionalities

- Mengembalikan notifikasi dengan urutan terbaru lebih dahulu.
- Mendukung filter berdasarkan status baca (is_read).
- Mendukung pagination dengan query parameter page dan limit.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Body

Field	Data Type	Mandatory	Description
page	Integer	false	Halaman yang diminta. Default: 1. Query param
limit	Integer	true	Jumlah item per halaman. Default: 20. Query param.
is_read	Boolean	true	Filter berdasarkan status baca. Opsional. Query param.

Request Example

```
// Query Parameters:
GET /notifications?page=1&limit=20&is_read=false
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
total	Integer	Total jumlah notifikasi.
unread_count	Integer	Jumlah notifikasi yang belum dibaca.
notifications	Array	Daftar notifikasi.

notifications[].id	String (UUID)	ID notifikasi.
notifications[].type	String	Tipe notifikasi. Lihat Enumerator Reference.
notifications[].channel	String	Channel pengiriman. Lihat Enumerator Reference.
notifications[].title	String	Judul notifikasi.
notifications[].message	String	Isi pesan notifikasi.
notifications[].is_read	Boolean	true jika sudah dibaca.
notifications[].sent_at	String	Waktu pengiriman (ISO 8601).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "total": 5, "unread_count": 2, "notifications": [{ "id": "uuid-n1", "type": "BILLING_REMINDER", "title": "Tagihan Jatuh Tempo", "message": "Cicilan jatuh tempo 3 hari lagi.", "is_read": false, "sent_at": "2024-02-12T08:00:00Z" }] }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`

PUT - /notifications/{id}/read

API Endpoint	/notifications/{id}/read
API Method	PUT
Description	Menandai notifikasi tertentu sebagai sudah dibaca.
Auth Required	Yes

API Functionalities

- Memvalidasi kepemilikan notifikasi oleh user yang sedang login.
- Mengubah is_read menjadi true pada notifikasi terkait.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. Obtain from POST /auth/token.

Request Example

```
// Tidak ada request body.
PUT /notifications/uuid-n1/read
```

Response Body

Field	Data Type	Description
success	Boolean	true jika berhasil ditandai.
message	String	Pesan konfirmasi.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Notifikasi ditandai sudah dibaca." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
403 Forbidden	`{ "success": false, "error": "Notifikasi ini bukan milik Anda." }`

Admin Service

GET - /admin/loans/applications

API Endpoint	/admin/loans/applications
API Method	GET
Description	Mengambil daftar pengajuan pinjaman untuk direview oleh Admin. Hanya dapat diakses oleh user dengan role ADMIN.
Auth Required	Yes (ADMIN)

API Functionalities

- Memvalidasi bahwa JWT token milik user dengan role ADMIN.
- Mendukung filter berdasarkan status pengajuan dan pagination.
- Menampilkan detail user, risk score, dan ringkasan data untuk membantu keputusan.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. User harus memiliki role ADMIN.

Request Body

Field	Data Type	Mandatory	Description
status	String	false	Filter status. Contoh: PENDING_MANUAL_REVIEW. Query param
page	Integer	true	Halaman. Default: 1. Query param.
limit	Integer	true	Item per halaman. Default: 20. Query param.

Request Example

```
// Query Parameters:
GET /admin/loans/applications?status=PENDING_MANUAL_REVIEW&page=1
```

Response Body

Field	Data Type	Description
success	Boolean	true jika request berhasil.
total	Integer	Total pengajuan yang sesuai filter.
applications	Array	Daftar pengajuan.
applications[].id	String (UUID)	ID pengajuan.
applications[].user.full_name	String	Nama lengkap pemohon.

Field	Data Type	Description
applications[].user.nik	String	NIK pemohon.
applications[].amount	Integer	Nominal pinjaman yang diajukan.
applications[].tenor_months	Integer	Tenor yang dipilih.
applications[].risk_score	Number	Skor risiko dari risk engine.
applications[].status	String	Status pengajuan saat ini.
applications[].created_at	String	Waktu pengajuan (ISO 8601).

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "total": 3, "applications": [{ "id": "uuid-zzz", "user": { "full_name": "Budi S.", "nik": "3201..." }, "amount": 6000000, "tenor_months": 6, "risk_score": 72.5, "status": "PENDING_MANUAL_REVIEW", "created_at": "2024-01-15T10:00:00Z" }] }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
403 Forbidden	`{ "success": false, "error": "Akses ditolak. Role ADMIN diperlukan." }`

POST - /admin/loans/applications/{id}/review

API Endpoint	/admin/loans/applications/{id}/review
API Method	POST
Description	Admin menyetujui atau menolak pengajuan pinjaman. Notifikasi otomatis dikirim ke user setelah keputusan disimpan.
Auth Required	Yes (ADMIN)

API Functionalities

- Memvalidasi bahwa JWT token milik user dengan role ADMIN.
- Mengubah status pengajuan menjadi APPROVED atau REJECTED.
- Jika APPROVED: membuat record pinjaman aktif dan jadwal cicilan, lalu memicu pencairan dana.
- Jika REJECTED: menyimpan alasan penolakan ke field rejection_reason.
- Mengirimkan notifikasi via email dan SMS ke user sesuai keputusan.

Request Header

Field	Description
Authorization	Bearer {access_token}. Required. User harus memiliki role ADMIN.
Content-Type	application/json

Request Body

Field	Data Type	Mandatory	Description
decision	String	true	Keputusan review: APPROVED atau REJECTED
notes	String	true	Catatan atau alasan keputusan. Wajib jika decision = REJECTED.

Request Example

```
// Contoh Approve:
{
  "decision" : "APPROVED",
  "notes"    : "Profil risiko memenuhi syarat."
}

// Contoh Reject:
{
  "decision" : "REJECTED",
  "notes"    : "Riwayat kredit menunjukkan tunggakan aktif."
}
```

Response Body

Field	Data Type	Description
success	Boolean	true jika keputusan berhasil disimpan.

Field	Data Type	Description
message	String	Konfirmasi bahwa notifikasi telah dikirim ke user.

Response Example

Status	Body (contoh)
200 OK	`{ "success": true, "message": "Keputusan disimpan dan notifikasi dikirim ke user." }`
401 Unauthorized	`{ "success": false, "error": "Token tidak valid atau sudah kadaluarsa." }`
403 Forbidden	`{ "success": false, "error": "Akses ditolak. Role ADMIN diperlukan." }`
404 Not Found	`{ "success": false, "error": "Pengajuan tidak ditemukan." }`